

Sprint 3 – Group Meeting Notes

Meeting Schedule with mentor (Steve)

- Sprint-3_Meeting-Notes: February 3 – February 17, 2026
- **Meeting Type:** Group meetings with mentor
- **Project:** Open Energy Dashboard (OED)

Role Assignment

- Brian Raymond

General Summary

During Sprint 3, the team met with the mentor to review current progress, discuss remaining challenges, and plan the next steps for ongoing security improvements in OED.

The discussion focused mainly on tasks that are still in progress, particularly **rate limiting**, **log sanitization**, and **pull request cleanup**.

Overall, the team continues to make steady progress, although a few tasks are moving slowly due to **testing limitations** and **branch management issues**.

Issue 12 – Rate Limiting / Brute Force Protection

The team reviewed the current status of Issue 12, which aims to protect the login system from brute-force attacks using **rate limiting**.

Work is still ongoing because the **current testing setup does not accurately reflect real rate-limit behavior**, causing some automated tests to bypass the protection.

The mentor emphasized that while the **security logic is correct**, the **testing structure must properly match real system behavior**.

Next Step:

Continue restructuring the route tests so rate-limiting behavior can be tested correctly without breaking automated testing.

Issue 16 – Log Injection and Input Sanitization

Issue 16 remains in progress. Work has started on the **most clearly affected route**, since multiple routes may require the same fix.

Two primary security risks were highlighted:

- Malicious input affecting **database behavior**
- Malicious input altering how **logs appear to administrators**

Possible solutions discussed included:

- Using **input sanitization methods** (such as DOMPurify)
- Creating a **standard helper function** that separates system messages from user input before logging

This approach would improve both **security** and **log clarity**.

Next Step:

Complete the fix on one route and then apply the same solution across other affected routes.

Pull Request #1544 – Branch Cleanup

Pull Request #1544 is currently **blocked** because it includes **unrelated CI/CD commits** from class work that should not be merged into the OED codebase.

Planned Résolution:

- Move CI/CD-related work to a **separate branch**
- Revert unrelated commits
- Clean up and finalize the pull request

Issue 9 & Issue 17 Updates

The team reviewed progress on both issues.

- **Issue 9:**
The fix has been implemented, and **testing is currently in progress** before final submission.
- **Issue 17:**
Work is still at an **early stage**. Current efforts focus on understanding the problem description and identifying affected areas of the system.

Mentor Guidance

Issue 17 is likely related to how **authentication tokens or cookies are stored and managed**.

The team was advised to:

- Review how OED currently **stores and passes tokens**
- Compare this behavior with **recommended secure practices**

- Consider **centralizing token-handling logic** if it is currently spread across multiple parts of the system

Mentor Feedback

Security Research – Vault and Hard-coded Values

The team also discussed research related to **hard-coded and plaintext configuration values**.

Key clarifications included:

- **Vault solutions** should be used only for **sensitive secrets** (passwords, tokens, keys), not for non-sensitive data such as ports.
- **Development or debugging configurations** should be separated from production settings, possibly through a **separate developer Docker configuration**.

Sprint Reflection

Sprint 3 progress remains steady, although several tasks are still in progress.

Main blockers:

- Testing limitations affecting **rate-limit validation**
- Branch and commit cleanup required for **PR #1544**

Despite these challenges, the team now has a **clearer direction** for completing the remaining security tasks.

Next Steps

- Continue restructuring tests for **Issue 12**
- Complete sanitization and logging fixes for **Issue 16**
- Clean and finalize **PR #1544**
- Finish testing **Issue 9** and begin deeper work on **Issue 17**
- Continue research on secure secret management (vault approach)